시스템 보안 운영

KOREA
코리아IT아카데미학원



class	정보보안 산업기사 취득과정 A
name	조채언

목 차

Ⅰ. 시스템 인프라 보안 환경 운영 ····· 3

가. 보안 인프라 네트워크 구성도 ····· 3

나. SSH 기반 접근 시도 탐지 및 차단 운영 ····· 3

Ⅱ. Owasp-zap ····· 5

Ⅲ. 취약점 패턴 추출, Snort 룰 작성 및 대응 방법 ····· 8

Ⅳ. 관리 계정 명령어 사용금지 및 일반 계정 su 전환 제한 ····· 11

가. 관리 계정 shutdown, reboot, halt, poweroff, init 0, init 1 명령어 사용금지 11

나. 다른 계정 su 사용 불가 설정 ····· 12

Ⅴ. DNS 보안 강화 및 운영 ····· 13

Ⅰ. 시스템 인프라 보안 환경 운영

가. 보안 인프라 네트워크 구성도



나. SSH 기반 접근 시도 탐지 및 차단 운영

1. SSH 접속

```
kali@kali:~$ ssh roror@10.0.0.200
Welcome
roror@10.0.0.200's password:
Welcome Test Motd
Web console: https://roror.co.kr:9090/ or https://10.0.0.200:9090/

Last login: Wed Jun 10 12:47:17 2026 from 10.0.0.133
roror@roror:~$
```

Kali Linux에서 Rocky Linux의 SSH에 접속을 시도하였다. 정상적으로 사용자 계정으로 로그인에 성공하여 공격 트래픽 생성 및 탐지 실습 환경이 정상적으로 구성된 것을 확인하였다.

2. Snort Rule 기반 SSH 탐지




```
snort -A console -q -u snort -g snort -c /etc/snort/snort_local.conf
06/10-05:36:50.412401  [**] [1:2018050505:0] ToDetected SSH [**] [Priority: 0]
TCP} 10.0.0.133:41740 -> 10.0.0.200:22
```

IPS 장비에서 Snort를 Local Rule 기반 IDS 모드로 실행한 뒤, Kali Linux에서 SSH 접속을 재시도하였다. Snort는 TCP 패킷을 분석하여 사전에 정의된 SSH 탐지 규칙에 매칭되는 트래픽을 탐지하고 경고 메시지를 출력하였다. 이를 통해 IDS 환경에서 SSH 접속 시도를 정상적으로 탐지할 수 있음을 확인하였다.

3. Snort IPS 기반 SSH 차단

vi local_ips.rules

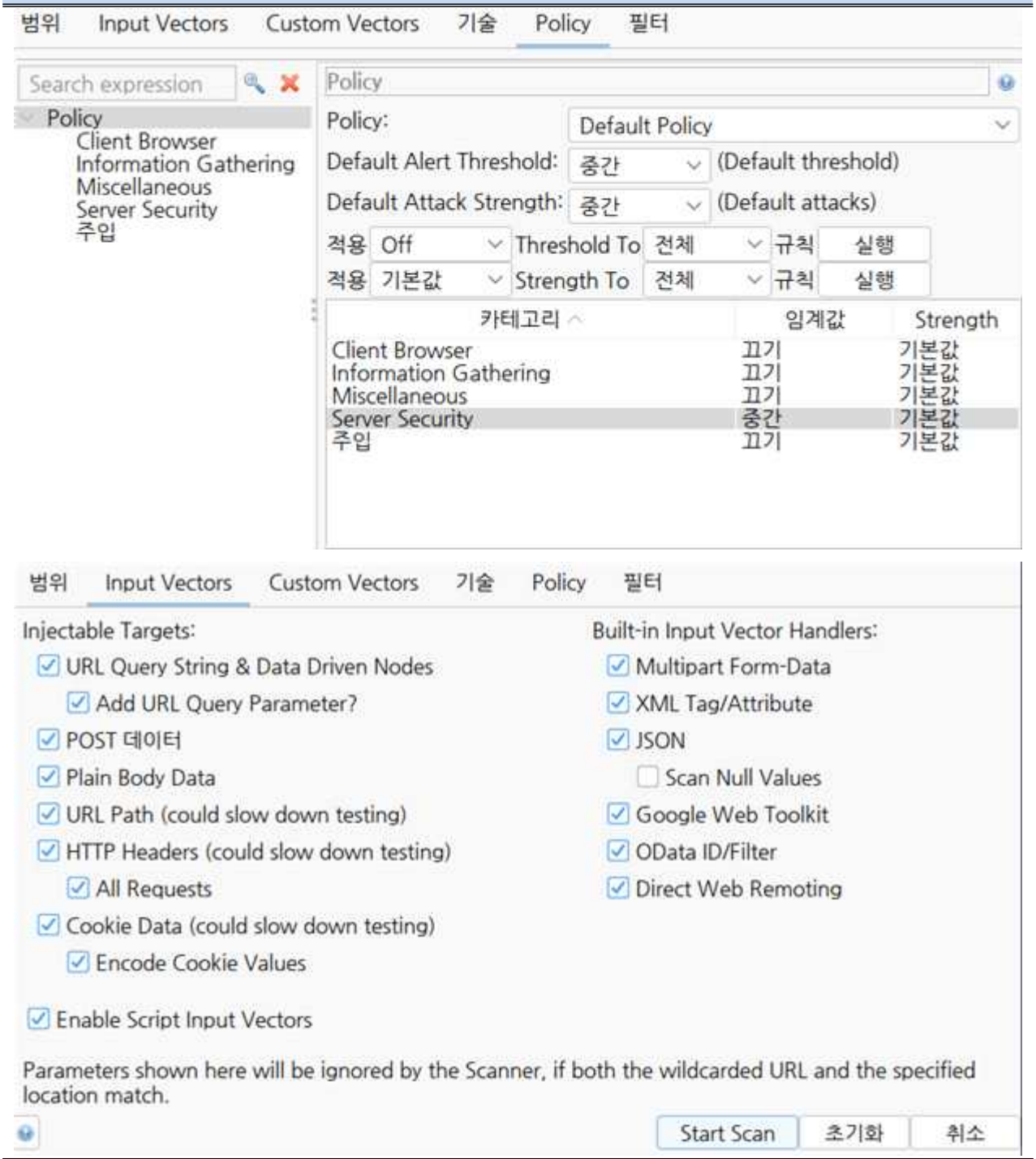
```
drop icmp any any -> any any (msg:"ToDetected ICMP..."; sid:2026051301;)
drop tcp any any -> any 22 (msg:"ToDetected SSH"; content:"SSH"; sid:2018050505;)

snort -Q -A console -q -u snort -g snort -i ens33:ens36 -N -c /etc/snort/snort_i
ps.conf
06/10-05:51:46.661122  [Drop] [**] [1:2026051301:0] ToDetected ICMP... [**] [Pri
ority: 0] {IPV6-ICMP} fe80::a877:fff:feaf:7112 -> ff02::16
06/10-05:51:47.428812  [Drop] [**] [1:2026051301:0] ToDetected ICMP... [**] [Pri
ority: 0] {IPV6-ICMP} fe80::a877:fff:feaf:7112 -> ff02::2
06/10-05:51:51.812209  [Drop] [**] [1:2026051301:0] ToDetected ICMP... [**] [Pri
ority: 0] {IPV6-ICMP} fe80::a877:fff:feaf:7112 -> ff02::2
06/10-05:51:52.331794  [Drop] [**] [1:2018050505:0] ToDetected SSH [**] [Priorit
y: 0] {TCP} 10.0.0.133:50090 -> 10.0.0.200:22
06/10-05:52:00.532116  [Drop] [**] [1:2026051301:0] ToDetected ICMP... [**] [Pri
ority: 0] {IPV6-ICMP} fe80::a877:fff:feaf:7112 -> ff02::2
06/10-05:52:17.108806  [Drop] [**] [1:2026051301:0] ToDetected ICMP... [**] [Pri
ority: 0] {IPV6-ICMP} fe80::a877:fff:feaf:7112 -> ff02::2
```

Snort를 IPS 모드로 전환하여 동일한 SSH 접속을 시도한 결과, 탐지된 패킷에 대해 Drop 정책이 적용되었다. 로그 상에서 Drop 메시지가 출력되었으며, 공격자의 SSH 연결 요청이 차단되어 접속하지 못하였다.

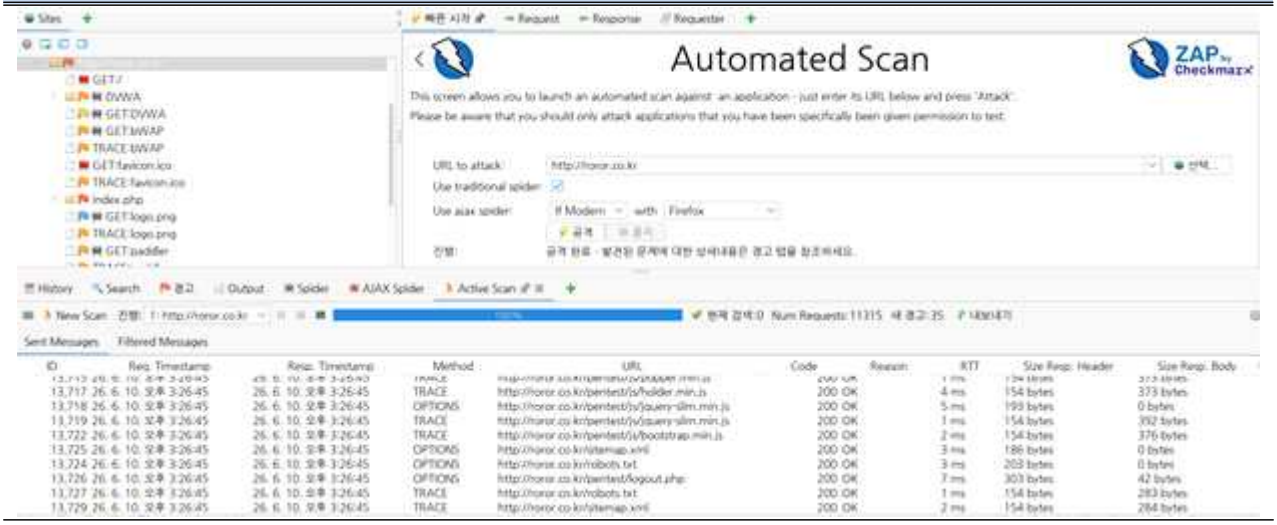
Ⅱ. Owasp-zap

1. Active Scan 옵션 설정



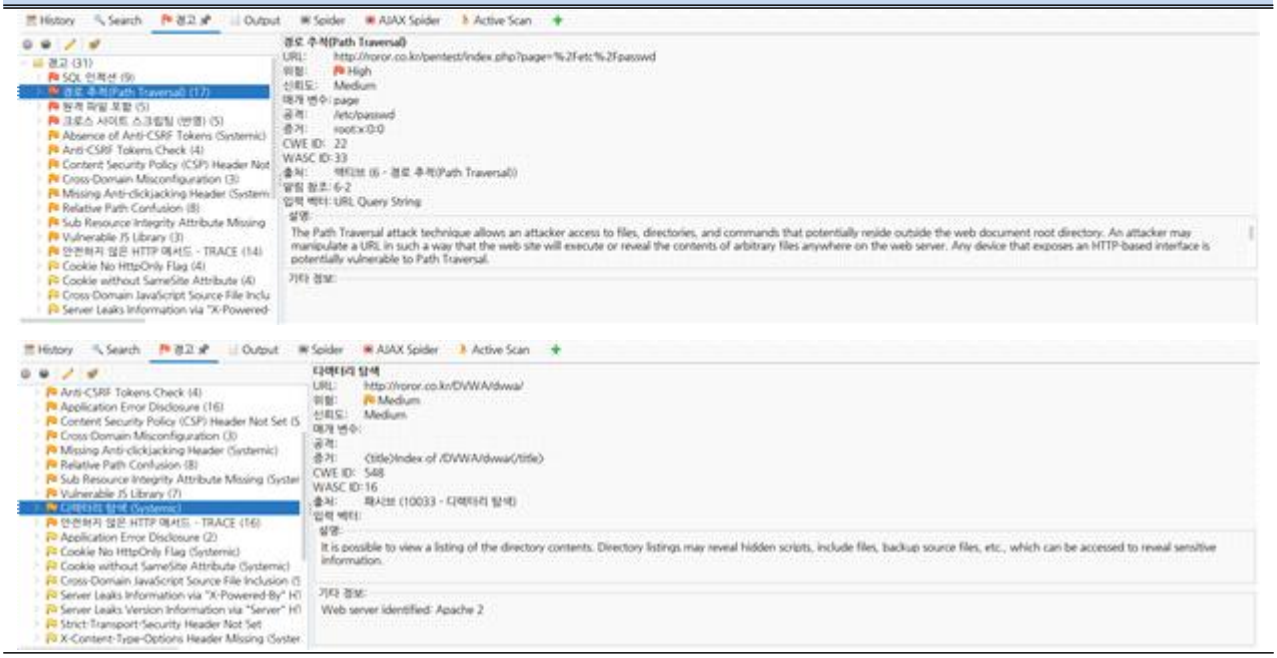
OWASP ZAP의 Active Scan 옵션을 설정한다. Policy 옵션에서 임계값을 전부 Off로 설정하고, Server Security만 중간으로 설정한다. Input Vectors에서 전부 체크하여 탐지하게 한다.

2. Active Scan 수행



설정한 값에 따라 Active Scan으로 웹 취약점 검사를 수행하였다. 또한, Spider 스캔도 수행하였다.

3. Path Traversal 및 Directory Browsing 취약점 탐지



Scan 수행 결과, 웹 서버에서 Path Traversal 및 Directory Browsing 취약점이 탐지되었다. Path Traversal 취약점은 상위 디렉터리 접근을 통해 중요 파일 노출 가능성을 가지며, Directory Browsing 취약점은 디렉터리 내부 파일 목록이 외부에 노출될 위험이 있음을 의미한다.

4. 취약점 분석 보고서

경로 추적(Path Traversal)

Source	raised by an active scanner (경로 추적(Path Traversal))
CWE ID	22
WASC ID	33
Reference	▪ https://owasp.org/www-community/attacks/Path_Traversal ▪ https://cwe.mitre.org/data/definitions/22.html

디렉터리 탐색

Source	raised by a passive scanner (디렉터리 탐색)
CWE ID	548
WASC ID	16
Reference	▪ https://cwe.mitre.org/data/definitions/548.html

탐지된 취약점 정보를 기반으로 OWASP ZAP 보고서를 생성하여 저장하였다. 보고서에는 취약점 유형, CWE/WASC 식별자, 상세 설명 및 참고 자료가 포함되어 있다.

Ⅲ. 취약점 패턴 추출, Snort 룰 작성 및 대응 방법

- **Path Traversal**
  - **정의** : 애플리케이션/시스템에 배정된 정해진 디렉터리·파일시스템 스코프를 벗어나 다른 디렉토리/스코프의 파일 및 데이터를 읽거나 접근하게 되는 취약점.
  - **영향** : 민감 파일(설정파일, 인증키, 사용자 데이터 등) 노출 → 추가 공격(인증 우회, 정보유출) 가능.
  - **대표 예시** : 잘못된 파일 경로 처리로 ../(상위경로) 등으로 접근 허용.
  - **탐지 포인트** : 파일 요청에 ../ 또는 인코딩된 경로가 포함된 접근 로그, 예외/에러 메시지에 파일 경로 노출.
  - **대응** : 입력값 정규화(화이트리스트), 파일 경로 정규화 및 루트 제한(베이스 디렉토리 고정), 최소권한 파일 접근.

- **Directory Browsing (디렉토리 브라우징)**
  - **정의** : 웹 서버에서 디렉토리 인덱싱 기능이 활성화되어 있거나 기본 인덱스 파일(index.html, index.php 등)이 존재하지 않을 때, 사용자가 해당 디렉토리 내부의 파일 및 하위 디렉토리 목록을 열람할 수 있는 취약점.
  - **영향** : 서버 내부 파일 구조 노출, 중요 파일(백업 파일, 설정 파일, 로그 파일 등) 유출 가능 → 추가 공격(정보수집, 인증 우회, 취약점 악용) 가능.
  - **대표 예시** : 웹 브라우저로 특정 디렉토리에 접근했을 때 Index of / 페이지가 출력되어 내부 파일 목록이 그대로 표시되는 경우.
  - **탐지 포인트** : URL 접근 시 Index of 문자열 확인, 웹 취약점 스캐너(OWASP ZAP, Nikto) 탐지 결과 확인, 디렉토리 내부 파일 목록 노출 여부 점검.
  - **대응** : 디렉토리에 index.html 파일 삽입, 웹 서버 설정에서 브라우징 기능 비활성화(Options -Indexes), 중요 디렉토리 접근 제어 설정, 불필요한 백업 파일 제거.

1. Snort Local Rule 기반 Path Traversal 탐지 규칙 추가

vi /etc/snort/rules/local.rules 에
alert tcp any any -> any 80 (msg:"WEB-ATTACK Path Traversal"; content:"../"; sid:1000001; rev:1;)
추가

/etc/snort/rules/local.rules에 Path Traversal 공격 탐지를 위한 규칙을 추가하였다. 해당 규칙은 HTTP 요청 패킷 내 ../ 문자열 패턴을 탐지하여 웹 루트 디렉토리를 벗어난 상위 경로 접근 시도를 식별하도록 구성하였다. 이를 통해 공격자가 /etc/passwd와 같은 시스템 중요 파일에 접근하려는 시도를 실시간으로 탐지할 수 있도록 설정하였다. 규칙에는 고유 SID(1000001)를 부여하여 이벤트 관리 및 로그 식별이 가능하도록 구성하였다.

2. Path Traversal 공격탐지 및 대응




```
snort -A console -q -u snort -g snort -c /etc/snort/snort.conf
06/10-07:34:10.647912  [**] [1:254:4] DNS SPOOF query response with TTL of 1 m
. and no authority [**] [Classification: Potentially Bad Traffic] [Priority: 2
{UDP} 10.0.0.200:53 -> 10.0.0.133:35452
06/10-07:34:58.568290  [**] [1:1122:5] WEB-MISC /etc/passwd [**] [Classificati
: Attempted Information Leak] [Priority: 2] {TCP} 10.0.0.133:52914 -> 10.0.0.2
:80
06/10-07:34:58.568290  [**] [1:1000001:1] WEB-ATTACK Path Traversal [**] [Prio
ty: 0] {TCP} 10.0.0.133:52914 -> 10.0.0.200:80
06/10-07:34:58.568290  [**] [1:1113:5] WEB-MISC http directory traversal [**] [
lassification: Attempted Information Leak] [Priority: 2] {TCP} 10.0.0.133:5291
-> 10.0.0.200:80
```

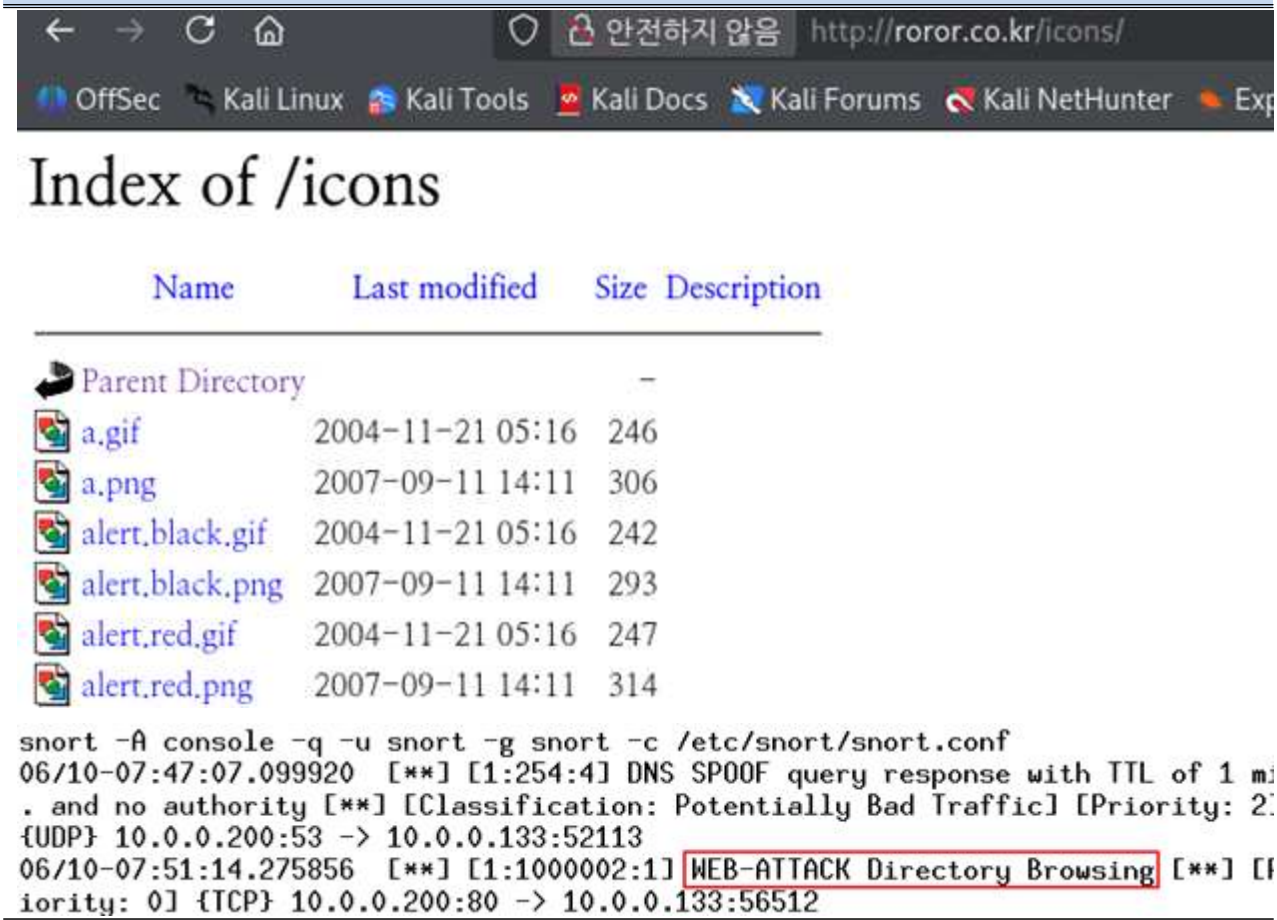
../../../../../../../etc/passwd와 같은 상위 디렉토리 접근 패턴을 사용하여 서버 내부 파일 접근을 시도하였으며, Snort는 이를 Path Traversal 규칙으로 탐지하였다. 이는 공격자가 웹 루트 범위를 벗어나 시스템 파일에 접근하려는 시도를 의미하며, /etc/passwd와 같은 민감 파일 노출 위험이 존재한다. 대응 방안으로는 입력값 검증, 파일 경로 정규화, 접근 가능한 디렉토리 범위 제한이 필요하다.

3. Snort Local Rule 기반 Directory Browsing 탐지 규칙 추가

vi /etc/snort/rules/local.rules 에
alert tcp any any -> any 80 (msg:"WEB-ATTACK Directory Browsing"; content:"Index of"; sid:1000002; rev:1;)
추가

/etc/snort/rules/local.rules에 Directory Browsing 공격 탐지를 위한 규칙을 추가하였다. 해당 규칙은 HTTP 응답 패킷 내 Index of 문자열 패턴을 탐지하여 디렉토리 인덱싱 기능 활성화로 인해 내부 파일 목록이 노출되는 상황을 식별하도록 설정하였다. 이를 통해 공격자가 서버 디렉토리 구조를 탐색하거나 중요 파일 정보를 수집하는 시도를 탐지할 수 있도록 구성하였다. 규칙에는 고유 SID(1000002)를 부여하여 별도의 탐지 이벤트로 관리할 수 있도록 하였다.

4. Directory Browsing 공격 탐지 및 대응



웹 서버의 특정 디렉토리(/icons) 접근 시 Index of /icons 페이지가 출력되어 디렉토리 내부 파일 목록이 노출되는 것을 확인하였다. 이는 Directory Browsing 취약점으로, 공격자가 서버 구조 및 내부 파일 정보를 수집할 수 있는 위험 요소이다. Snort는 해당 접근 시도를 WEB-ATTACK Directory Browsing 규칙으로 탐지하였다. 대응 방안으로는 디렉토리 인덱싱 비활성화, 기본 index 파일 생성, 중요 디렉토리 접근 통제 설정이 필요하다.

IV. 관리 계정 명령어 사용금지 및 일반 계정 su 전환 제한

가. 관리 계정 shutdown, reboot, halt, poweroff, init 0, init 1 명령어 사용금지

1. 시스템 종료 및 재부팅 명령 제한 설정

```
alias shutdown='echo "사용 금지"'
alias reboot='echo "사용 금지"'
alias halt='echo "사용 금지"'
alias poweroff='echo "사용 금지"'

init() {
    if [ "$1" = "0" ] || [ "$1" = "1" ]; then
        echo "init 0, init 1 사용 금지"
    else
        /usr/sbin/init "$@"
    fi
}
"~/.bashrc" 37L, 814B
```

source ~/.bashrc

사용자의 ~/.bashrc 파일에 alias 및 함수(Function)를 추가하여 시스템 종료 및 재부팅 관련 명령어 사용을 제한하였다. shutdown, reboot, halt, poweroff 명령어를 실행할 경우 실제 명령이 수행되지 않고 "사용 금지" 메시지가 출력되도록 설정하였다. 또한 init 명령어에 대해 런레벨 0(종료), 1(단일 사용자 모드) 진입을 제한하여 비인가 사용자의 시스템 운영 중단을 방지하도록 구성하였다. 설정 적용을 위해 source ~/.bashrc 명령으로 즉시 반영하였다.

2. 시스템 종료 및 재부팅 명령 제한 적용 확인

```
roror@roror:~$ reboot
사용 금지
roror@roror:~$ shutdown
사용 금지
roror@roror:~$ halt
사용 금지
roror@roror:~$ poweroff
사용 금지
roror@roror:~$ init 0
init 0, init 1 사용 금지
roror@roror:~$ init 0 1
init 0, init 1 사용 금지
```

설정 적용 후 reboot, shutdown, halt, poweroff, init 0, init 1 명령을 실행하여 제한 정책이 정상적으로 동작하는지 확인하였다. 테스트 결과 각 명령 실행 시 실제 시스템 종료나 재부팅이 수행되지 않고, 설정한 차단 메시지가 출력되었다.

나. 다른 계정 su 사용 불가 설정

1. PAM 설정 파일 수정

```
#%PAM-1.0
auth            required        pam_env.so
auth            sufficient      pam_rootok.so
# Uncomment the following line to implicitly trust users in the "wheel" group.
#auth           sufficient      pam_wheel.so trust use_uid
# Uncomment the following line to require a user to be in the "wheel" group.
auth            required        pam_wheel.so use_uid
auth            substack        system-auth
auth            include         postlogin
account         sufficient      pam_succeed_if.so uid = 0 use_uid quiet
account         include         system-auth
password        include         system-auth
session         include         system-auth
session         include         postlogin
session         optional        pam_xauth.so
```

auth required pam_wheel.so use_uid 줄의 주석을 해제하여 활성화하였다. 이 설정이 적용되면, 시스템의 관리자 그룹에 속하지 않은 일반 사용자는 su 명령어를 사용할 수 없게 제한된다.

2. 일반 계정 생성 및 su 명령어 차단 테스트 결과 확인

```
root@roror:/home/roror# useradd user
root@roror:/home/roror# passwd user
New password:
BAD PASSWORD: The password is shorter than 8 characters
Retype new password:
passwd: password updated successfully
```

```
user@roror:~$ su
Password:
su: Permission denied
```

user라는 이름의 새로운 일반 계정을 생성하고 비밀번호를 설정한다. 생성된 일반 계정(user@roror)으로 로그인하거나 전환한 뒤, 다른 계정으로 전환하기 위해 su 명령어를 입력하였을 때, 비밀번호를 올바르게 입력하더라도, 해당 계정이 wheel 그룹에 속해 있지 않기 때문에 권한 거부 오류가 발생하며 차단된다.

V. DNS 보안 강화 및 운영

1. DNS 서버 설정 파일(named.conf) 수정

```
options {
        listen-on port 53 { 10.0.0.200; };
        listen-on-v6 port 53 { ::1; };
        directory       "/var/named";
        dump-file       "/var/named/data/cache_dump.db";
        statistics-file "/var/named/data/named_stats.txt";
        memstatistics-file "/var/named/data/named_mem_stats.txt";
        secroots-file   "/var/named/data/named.secroots";
        recursing-file  "/var/named/data/named.recursing";
        //allow-query     { localhost; internal-network; };
        allow-query     { any; };
```

DNS 서버가 내부 IP 주소(10.0.0.200)의 53번 포트에서 질의를 대기하도록 지정하고, 기존의 특정 네트워크 제한(localhost; internal-network;) 설정을 주석 처리한 뒤 allow-query { any; };로 변경하여 모든 호스트로부터의 DNS 쿼리 요청을 허용하도록 설정하였다.

2. 방화벽 DNS 서비스 허용 설정

```
root@roror:/home/roror# firewall-cmd --permanent --add-service=dns
Warning: ALREADY_ENABLED: dns
success
root@roror:/home/roror# firewall-cmd --reload
success
```

외부 사용자가 DNS 서버에 접근할 수 있도록 firewall-cmd 명령어를 사용하여 방화벽에 DNS 서비스(53번 포트)를 영구적으로 허용하는 규칙을 추가하고, 변경된 설정을 시스템에 즉시 적용(reload)하여 정상적으로 반영되었는지 확인한다.

3. IDS를 통한 DNS 보안 위협 탐지

```
snort -A console -q -u snort -g snort -c /etc/snort/snort.conf
06/10-07:47:07.099920  [**] [1:254:4] DNS SPOOF query response with TTL of 1 min
. and no authority [**] [Classification: Potentially Bad Traffic] [Priority: 2]
{UDP} 10.0.0.200:53 -> 10.0.0.133:52113
```

Snort를 콘솔 출력 모드로 실행하여 설정된 규칙 기반으로 네트워크 패킷을 감시하던 중, DNS 서버(10.0.0.200)가 클라이언트(10.0.0.133)에게 보낸 응답 패킷에서 DNS 스푸핑 공격 의심 징후를 성공적으로 탐지하여 경고 로그를 출력하였다.